

GenAI: Its Security Risks & Mitigation Approaches

OWASP has named sensitive information disclosure the second most critical security issue for AI applications. This session maps where that risk actually lives: the tools people already use, the models companies build on, and the frameworks that keep both in check.



Presenter: Marty M. Weiss, Enterprise Security Advisor, Proofpoint

- 01 Why GenAI, why now
- 02 Where the risk sits
- 03 AI abuse & misuse: the OWASP 10
- 04 Real-world examples
- 05 Frameworks for safe adoption
- 06 Recommendations

QUICK RECALL

Foundation models sit inside ML; LLMs are one kind. Risk splits into end-user, corporate and platform layers. The OWASP Top 10 for LLMs is the one list worth memorizing.

Why GenAI, why now

Three forces made generative AI possible at this scale: an explosion of large, diverse training data; a jump in GPU/TPU power, cloud compute and open-source tooling; and deep learning advances, chiefly the transformer architecture plus reinforcement learning from human feedback. Together they turned foundation models from a research curiosity into something every business function now touches, from communications and code to synthetic data, design and automation. Proofpoint's own research shows the tension this creates: 60% of CISOs say enabling AI tool use is a top priority for the next two years, and the same 60% are worried about losing customer data to public GenAI platforms.

60%

say enabling GenAI use is a top priority over the next two years

60%

are concerned about losing customer data to public GenAI tools

Foundation models sit inside machine learning the way ML sits inside AI: pre-trained, general-purpose, and opaque, spanning LLMs, diffusion, GANs, multimodal and audio models. Large language models are the family everyone means when they say "AI" today, split between proprietary models (GPT-5, Claude, Gemini) and open-source ones (LLaMA, Mistral, Falcon). How much risk a given deployment carries depends less on which model and more on how it learns your data:

Pre-training

Training an LLM from scratch. Needs massive datasets and heavy compute, which is why most organizations never do this.

Fine-tuning

Adapting a pre-trained model to a specific domain using thousands of labeled examples.

RAG / contextual data

Combining an LLM with external retrieval, using vectors to pull in relevant context at query time.

Prompt engineering

Structured prompts, templates and chains that steer outputs without touching the model itself,

cutting hallucinations along the way.

Complexity and compute cost fall in that order, left to right, which is exactly why most GenAI risk today shows up in prompts and retrieval rather than in model training.

02 · Where the risk sits

Where the risk sits

Proofpoint frames GenAI risk across technology, process and human behavior, and groups it into six lenses: privacy, regulatory, social, IP protection, ethical and security. Privacy risk shows up as no right to be forgotten, personal data landing in training sets, PII leaking through user prompts, and vendors handling data opaquely. Regulatory risk covers bias and discrimination, disputed model or algorithm claims, and liability under a fast-moving patchwork of rules including the EU AI Act, Colorado's AI Act, the Biden-Harris responsible-AI actions, and California's automated decision tools regulation.

A second, more practical lens splits data security risk by who's doing the deploying:

End-user use of GenAI

Shadow AI usage, accidental data sharing, prompt injection and leakage, compliance breaches, and sensitive output getting reshared, all from everyday tools like ChatGPT, Claude and Copilot.

Corporate use of foundation models

Fine-tuning that embeds sensitive data, weak governance in RAG pipelines, data crossing tenant boundaries, exposed model weights or vector databases, and AI supply-chain risk.

Platform & ecosystem

Risk inherited from the infrastructure GenAI runs on, orchestration frameworks like LangChain and cloud/data platforms such as AWS and Snowflake.

AI abuse & misuse: the OWASP Top 10

Proofpoint organizes GenAI abuse into three buckets, data, trust and usage, and it maps directly onto the 2025 OWASP Top 10 for LLM & GenAI (genai.owasp.org/llm-top-10). It's the single most useful checklist from the session, worth keeping as a reference.

☒ Data ☒ Trust ☒ Usage

Collapse all

– Prompt injection

DATA

Crafted inputs manipulate the model into unintended actions. Direct injection overwrites system prompts outright; indirect injection hides instructions in content the model later ingests, like a document or web page.

– Sensitive information disclosure

DATA

PII, financial, health, business, security and legal data can all surface through an LLM. Proprietary models carry extra exposure through their training methods and source code.

– Supply chain

DATA

LLM supply chains inherit risk from training data, third-party pre-trained models and hosting platforms, causing bias, breaches or outright failures in ways traditional software supply chains don't.

– Data and model poisoning

DATA

Manipulating pre-training, fine-tuning or embedding data introduces vulnerabilities, bias or backdoors, degrading outputs or compromising whatever system consumes them downstream.

– Improper output handling

USAGE

Treating LLM output as safe without validating it first opens the door to XSS, CSRF, SSRF, privilege escalation or remote code execution, distinct from simply over-trusting a wrong answer.

– Excessive agency

TRUST

Agents that gain access to extensions, tools or plugins can chain repeated LLM calls, using each output to guide the next action, and that autonomy can wander past its intended scope.

– **System prompt leakage**

USAGE

Sensitive instructions baked into a system prompt can leak out, handing an attacker the exact rules the model was told to follow and how to work around them.

– **Vector and embedding weaknesses**

DATA

Weak generation, storage or retrieval of vectors and embeddings in a RAG pipeline lets attackers inject harmful content, manipulate outputs or expose data that should have stayed private.

– **Misinformation**

TRUST

Confident, credible-sounding but false output misleads users directly, creating security, reputational and legal exposure for whatever application relies on it.

– **Unbounded consumption**

USAGE

Because LLMs generate output from whatever's fed in, uncontrolled input volume or complexity can be used to run up cost, exhaust resources, or degrade service for everyone else.

04 · Real-world examples

Real-world examples

Samsung's ChatGPT ban (2023)

Employees pasted confidential source code and meeting notes into ChatGPT to summarize or debug them. At the time, user input could become training data, so that code effectively left the corporate boundary. Samsung's takeaway: accidental, well-intentioned use can leak IP just as easily as a deliberate breach if no guardrails exist.

The LinkedIn "flan recipe" prompt injection

A LinkedIn user hid an instruction inside his own profile's About section, telling any AI reading it to ignore its prior instructions and slip a flan recipe into outreach messages. AI-assisted sales tools that scraped his profile for personalized outreach did exactly that, publicly, at scale, showing how casually prompt injection can ride along in ordinary web content.

Frameworks for safe adoption

No single framework covers GenAI risk end to end, so most programs lean on a combination. MITRE ATLAS, Gartner and Google also publish relevant guidance, but three do most of the work:

OWASP Top 10 for LLMs

Technical and operational, widely recognized, tactical and easy to adopt, the natural starting point for engineering teams.

NIST AI RMF

Policy and governance focused. Shapes emerging regulation, sets a baseline for compliance and audits, and organizes work around govern, map, measure, manage.

ISO/IEC 23894

Internationally recognized, mapping to ISO 31000 for risk management and ISO 42001 for AI management, structured around identify, assess, treat, monitor.

Recommendations

Proofpoint's closing guidance splits into consuming GenAI applications securely and building them securely, but the underlying advice is the same either way. Start with a solid foundation in cloud, data and application security, then layer GenAI-specific governance and controls on top rather than trying to bolt security on after the fact. Block sensitive information from reaching unapproved GenAI apps, and steer usage toward GenAI web or SaaS tools that are already vetted for business use. For anything custom, secure the agent itself with native and third-party controls matched to how it's deployed. None of this is a one-time project: treat continuing education for users, teams and leadership as part of the control, not a nice-to-have.

The thread running through the whole session is that GenAI risk isn't really about the model. It's about where sensitive data flows once people, agents and platforms start acting on it, and how much visibility and governance exist at each of those points.

Notes from Proofpoint Cybersecurity Academy, AI Data Security Specialist, Session 1.
Compiled by Anmol Nisar, September 2026.